ESCUELA SUPERIOR de Innovación y Tecnología

GRUPO No. 45

Nombre del proyecto:

“Automatizacion de hardening de servidores Linux con Ansible en la Alcaldia Municipal de Santa Ana”

Asignatura / Módulo:

Estancia Profesional de Ciberseguridad”

Integrantes del grupo:

Melvin Alejandro Mendez Lemus (Lider)

Edwin Alexander Mendoza Mejia

Samuel Antonio Mendoza Mejia

Docente

Ing. Damaris Abigail Alas

Duración y modalidad del proyecto

Duración proyectada: 10 semanas (4 para la fase de requerimientos, 6 para la fase de matriz de riesgo).

Modalidad: Virtual.

Fecha de elaboración. 23 de Enero de 2026

Estancia Profesional
ESCUELA SUPERIOR DE INNOVACIÓN Y TECNOLOGÍA

•

1. Datos Generales del Escenario

Objetivo de esta sección: Resumir la información básica y el alcance del escenario que el grupo va a trabajar.

El presente escenario corresponde al proyecto **"Automatización del Hardening de Servidores Linux mediante Ansible"**, el cual se desarrolla en el contexto de la **Alcaldía Municipal de Santa Ana**, una entidad pública de carácter gubernamental responsable de la administración municipal y la prestación de servicios a la ciudadanía.

El proyecto tiene como objetivo principal **fortalecer la seguridad de los servidores Linux** que soportan servicios críticos municipales, mediante la **automatización de configuraciones de hardening**, aplicando buenas prácticas y estándares de seguridad. Esto permitirá reducir riesgos asociados a accesos no autorizados, errores de configuración, vulnerabilidades técnicas y fallos operativos.

El alcance del escenario incluye el análisis del entorno tecnológico actual, la identificación de activos críticos, amenazas y vulnerabilidades, así como la definición de requerimientos funcionales y no funcionales. Asimismo, se contempla el diseño de una **matriz de gestión de riesgos** y la propuesta de controles de mitigación, orientados a mejorar la confidencialidad, integridad y disponibilidad de la información institucional.

El desarrollo del proyecto se realizará en modalidad virtual, con una duración estimada de **10 semanas**, organizadas en dos fases: la **definición de requerimientos del escenario** y el **diseño de la matriz de riesgos**, sirviendo como base para futuras implementaciones de automatización y seguridad en la infraestructura tecnológica municipal.

1.1. Nombre del proyecto o escenario

"Automatización del Hardening de Servidores Linux mediante Ansible"

•

1.2. Entidad demandante seleccionada

Alcaldía Municipal de Santa Ana. Es una entidad pública de carácter gubernamental, de tamaño mediano, encargada de la administración municipal, prestación de servicios públicos y gestión administrativa y tecnológica para la ciudadanía.

1.3. Duración y modalidad del proyecto

Duración: 10 semanas.

Modalidad: Virtual.

Fases:

Fase 1: Definición de requerimientos del escenario (4 semanas).

Fase 2: Diseño de matriz de riesgo del escenario (6 semanas).

•

Organización del trabajo:

Fase 1: Definición de requerimientos del escenario (4 semanas, semanas 1 a 4).
Fase 2: Diseño de matriz de riesgo del escenario (6 semanas, semanas 5 a 10).

2. Descripción del Contexto del Escenario

Objetivo de esta sección: Demostrar que el grupo comprende el contexto general donde se desarrollará el proyecto o solución.

2.1. Entidad demandante y contexto general

La Alcaldía Municipal de Santa Ana gestiona información administrativa, financiera y ciudadana mediante sistemas tecnológicos que requieren altos niveles de disponibilidad y seguridad. El proyecto es clave para fortalecer la protección de servidores Linux que soportan servicios críticos municipales.

2.2. Servicios, procesos o activos principales involucrados

Servicios de autenticación, monitoreo, gestión de sistemas y seguridad de la información.

Infraestructura híbrida (on-premise y nube).

2.3. Situación actual (estado actual del escenario)

Actualmente, la gestión de seguridad se realiza de forma manual, con configuraciones inconsistentes y sin estandarización del hardening.

2.4. Necesidad del proyecto o solución propuesta

Automatizar el hardening permitirá reducir riesgos, mejorar tiempos de respuesta y asegurar cumplimiento de buenas prácticas de seguridad

•

3. Actores y Procesos del Escenario

Objetivo de esta sección: Identificar quiénes participan en el escenario y qué procesos son críticos.

3.1. Actores del escenario

En el escenario de la **Alcaldía Municipal de Santa Ana**, participan los siguientes actores clave:

Equipo de Tecnologías de la Información (TI):
Responsable de la administración general de la infraestructura tecnológica municipal. Supervisa la operación de los servidores, coordina la implementación de cambios, valida configuraciones y asegura la continuidad de los servicios institucionales.

Administradores de Sistemas Linux:
Encargados de la instalación, configuración y mantenimiento de los servidores Linux. Ejecutan tareas de hardening, administración de usuarios, gestión de servicios, aplicación de parches y despliegue de configuraciones automatizadas mediante Ansible.

Equipo de Seguridad de la Información (Blue Team):
Responsable de definir políticas de seguridad, monitorear eventos e incidentes, analizar vulnerabilidades y verificar el cumplimiento de controles de seguridad. Colabora en la definición de estándares de hardening y en la revisión de alertas generadas por los sistemas.

Usuarios internos (personal administrativo y técnico):
Utilizan los sistemas y servicios soportados por los servidores Linux para el desempeño de sus funciones. Aunque no administran los sistemas, sus actividades pueden generar eventos relevantes que deben ser monitoreados desde el punto de vista de la seguridad.

•

3.2. Procesos críticos del escenario

Los procesos críticos relacionados con el proyecto son los siguientes:

- **Gestión de parches y actualizaciones:**
  Proceso orientado a la identificación, evaluación y aplicación oportuna de parches de seguridad en los servidores Linux. La automatización mediante Ansible permite reducir errores humanos, asegurar la consistencia de las configuraciones y disminuir la exposición a vulnerabilidades conocidas.

- **Control de accesos y autenticación:**
  Incluye la administración de usuarios, grupos y privilegios, así como la implementación de mecanismos seguros de autenticación (por ejemplo, políticas de contraseñas, acceso SSH seguro y deshabilitación de cuentas innecesarias). Este proceso busca garantizar que solo personal autorizado tenga acceso a los sistemas.

- **Monitoreo y registro de eventos de seguridad:**
  Consiste en la supervisión continua de los servidores para detectar comportamientos anómalos, intentos de acceso no autorizado, fallos de servicios o cambios no autorizados en la configuración. El registro centralizado de logs facilita la trazabilidad y el análisis posterior.

- **Detección y respuesta a incidentes de seguridad:**
  Proceso que permite identificar incidentes, evaluar su impacto y ejecutar acciones de contención, mitigación y recuperación. Incluye la notificación a los actores responsables, la documentación del incidente y la aplicación de medidas correctivas para evitar recurrencias.

- **Despliegue y validación de configuraciones de hardening:**
  Proceso mediante el cual se aplican configuraciones de seguridad estandarizadas en los servidores Linux utilizando playbooks de Ansible, asegurando que las políticas definidas se mantengan de forma consistente en toda la infraestructura.

•

4. Identificación de Activos del Escenario

Objetivo de esta sección: Identificar los activos más importantes del escenario y su nivel de criticidad.

4.1. Listado de activos relevantes

Los principales activos relacionados con el escenario de **automatización del hardening de servidores Linux con Ansible** en la **Alcaldía Municipal de Santa Ana** son los siguientes:

- **Servidores Linux:**
  Infraestructura central que soporta los sistemas y servicios municipales. Estos servidores alojan aplicaciones, servicios de red, bases de datos y procesos críticos para la operación administrativa y tecnológica de la municipalidad.
- **Sistemas municipales:**
  Conjunto de aplicaciones y plataformas utilizadas para la gestión administrativa, financiera y operativa de la alcaldía, tales como sistemas internos de gestión, portales institucionales y servicios digitales dirigidos a la ciudadanía.
- **Bases de datos institucionales:**
  Repositorios que almacenan información sensible y crítica, incluyendo datos administrativos, financieros, registros de usuarios, transacciones y otros datos relevantes para la gestión municipal.
- **Herramientas y plataformas de seguridad:**
  Soluciones utilizadas para proteger, monitorear y auditar la infraestructura tecnológica, tales como firewalls, sistemas de detección o prevención de intrusiones (IDS/IPS), herramientas de monitoreo, sistemas de registro de eventos y soluciones de automatización como Ansible.

A continuación, se listan activos alineados al escenario **“Acceso remoto seguro mediante VPN (OpenVPN/WireGuard) para una fintech (FinPay)”**. Cada activo incluye: qué es/para qué se usa y por qué es relevante para el proyecto.

4.2 Clasificación de criticidad de activos

De acuerdo con su impacto en la operación, seguridad y continuidad de los servicios municipales, los activos se clasifican de la siguiente manera:

- **Servidores Linux – Crítico:**
  Son esenciales para el funcionamiento de los sistemas municipales. La indisponibilidad, alteración o compromiso de estos servidores afectaría directamente la continuidad de los servicios institucionales y podría generar impactos operativos y de seguridad significativos.
- **Bases de datos institucionales – Crítico:**
  Contienen información sensible y estratégica para la alcaldía. Una pérdida, alteración o acceso no autorizado a estos activos tendría consecuencias graves en términos de confidencialidad, integridad y cumplimiento normativo.
- **Sistemas municipales – Crítico:**
  Permiten la ejecución de procesos administrativos y de atención a la ciudadanía. Su falla o compromiso afectaría la calidad del servicio y la operación diaria de la entidad.

Herramientas y plataformas de seguridad – Importante:
Aunque no generan servicios directos a los usuarios finales, son fundamentales para la protección, detección y mitigación de incidentes de seguridad. Su mal funcionamiento incrementaría el nivel de riesgo de los activos críticos.

5. Amenazas y Vulnerabilidades del Escenario

Objetivo de esta sección: Identificar las amenazas y vulnerabilidades que afectan directamente a los activos críticos del escenario, considerando los riesgos previamente definidos en la matriz de gestión de riesgos.

5.1 Amenazas relevantes

En el contexto de la **Alcaldía Municipal de Santa Ana**, y de acuerdo con la matriz de riesgos elaborada, se identifican las siguientes amenazas que impactan a los servidores Linux y a los sistemas municipales:

- **Accesos no autorizados a los servidores Linux:**
  Amenaza asociada a intentos de ingreso indebido por parte de usuarios internos o externos, que puede comprometer la confidencialidad e integridad de la información institucional (R-01).
- **Explotación de vulnerabilidades conocidas en sistemas Linux:**
  Riesgo derivado del aprovechamiento de fallas de seguridad presentes en el sistema operativo o servicios instalados, principalmente cuando no se aplican parches de manera oportuna (R-03).
- **Errores de configuración en los servidores:**
  Amenaza relacionada con configuraciones incorrectas o inconsistentes, producto de procesos manuales o falta de estandarización, que pueden generar brechas de seguridad (R-02 y R-05).
- **Cambios no controlados en la infraestructura tecnológica:**
  Amenaza que surge cuando se realizan modificaciones sin mecanismos de trazabilidad o auditoría, afectando la estabilidad y seguridad de los servicios (R-04).
- **Interrupción de servicios críticos municipales:**
  Amenaza que puede provocar la indisponibilidad de sistemas esenciales para la operación administrativa y la atención a la ciudadanía (R-06).

5.2 Vulnerabilidades del escenario

Las amenazas identificadas se ven potenciadas por las siguientes vulnerabilidades, directamente relacionadas con los riesgos definidos en la matriz:

- **Configuraciones inseguras en servidores Linux:**
  Uso de parámetros por defecto, servicios innecesarios habilitados o controles de acceso débiles, lo que facilita accesos no autorizados y errores de configuración (R-01 y R-05).

- **Ausencia de automatización en el hardening de servidores:**
  Dependencia de configuraciones manuales que incrementan la probabilidad de errores humanos y generan inconsistencias entre servidores (R-02 y R-05).
- **Gestión manual de parches y actualizaciones:**
  Falta de un proceso automatizado para la aplicación de parches de seguridad, lo que expone los sistemas a la explotación de vulnerabilidades conocidas (R-03).
- **Limitada trazabilidad y auditoría de cambios:**
  Insuficientes mecanismos para registrar y auditar modificaciones en la configuración de los servidores, dificultando la detección y análisis de incidentes (R-04).
- **Procesos no controlados que afectan la disponibilidad:**
  Cambios o configuraciones que pueden impactar negativamente la continuidad de los servicios municipales (R-06).

---

6. Requerimientos del Escenario

Objetivo de esta sección: Definir los requerimientos necesarios para mitigar los riesgos identificados, garantizando la seguridad, estabilidad y continuidad de los servicios soportados por los servidores Linux.

6.1 Requerimientos funcionales

- **RF-01:** Automatizar la aplicación de políticas de hardening en los servidores Linux mediante el uso de Ansible, con el fin de estandarizar configuraciones y reducir accesos no autorizados (R-01, R-02 y R-05).
- **RF-02:** Automatizar la configuración segura de servicios críticos, incluyendo el fortalecimiento del acceso SSH, la gestión de usuarios y permisos, y la deshabilitación de servicios innecesarios (R-01 y R-05).
- **RF-03:** Implementar la automatización del proceso de gestión de parches y actualizaciones de seguridad en los servidores Linux, reduciendo la exposición a vulnerabilidades conocidas (R-03).
- **RF-04:** Garantizar la trazabilidad y el control de cambios mediante el registro y documentación automática de las configuraciones aplicadas a través de playbooks de Ansible (R-04).

6.2 Requerimientos no funcionales

- **RNF-01:** Garantizar altos niveles de **confidencialidad, integridad y disponibilidad** de los sistemas y la información municipal durante y después de la aplicación de las políticas de hardening (R-01, R-03 y R-06).
- **RNF-02:** Asegurar que la solución de automatización sea **estable y escalable**, permitiendo su aplicación progresiva en nuevos servidores sin afectar la operación existente (R-02 y R-06).
- **RNF-03:** Garantizar la **confiabilidad y repetibilidad** de los procesos de hardening automatizados, minimizando errores humanos y configuraciones inconsistentes (R-02 y R-05).

7. Priorización de Requerimientos

Objetivo de esta sección: Establecer la prioridad de los requerimientos definidos, considerando el nivel de riesgo asociado a cada uno y su impacto en la seguridad y continuidad de los servicios municipales.

Los requerimientos del escenario han sido priorizados con base en la **matriz de gestión de riesgos**, dando mayor importancia a aquellos que mitigan riesgos clasificados como **Altos, Muy Altos o Extremos**.

Los requerimientos **RF-01** y **RF-02** se consideran de **prioridad alta**, ya que están directamente relacionados con la mitigación de accesos no autorizados, errores de configuración y fallos derivados de procesos manuales (R-01, R-02 y R-05).

El requerimiento **RF-03** también se clasifica como de **prioridad alta**, debido a su impacto directo en la reducción del riesgo de explotación de vulnerabilidades conocidas por falta de parches de seguridad (R-03).

El requerimiento **RF-04** se establece como de **prioridad media-alta**, ya que contribuye a mejorar la trazabilidad, el control de cambios y la capacidad de auditoría, reduciendo riesgos asociados a modificaciones no controladas (R-04).

Los **requerimientos no funcionales (RNF)** se consideran transversales y de **prioridad alta**, dado que garantizan la disponibilidad, estabilidad y confiabilidad de los servicios municipales, especialmente frente al riesgo de interrupción de servicios críticos (R-06).

8. Restricciones y Supuestos del Escenario

Objetivo de esta sección: Definir las limitaciones y condiciones bajo las cuales se desarrollará el escenario, considerando el contexto organizativo y tecnológico de la entidad.

8.1 Restricciones del escenario

- **Uso obligatorio de servidores Linux:**
  El escenario se limita a infraestructuras basadas en sistemas operativos Linux, dado que los activos críticos identificados corresponden a este tipo de plataforma.
- **Uso obligatorio de Ansible como herramienta de automatización:**
  La implementación del hardening debe realizarse exclusivamente mediante Ansible, como solución estandarizada para la automatización de configuraciones de seguridad.
- **Disponibilidad limitada de personal técnico:**
  La alcaldía cuenta con recursos humanos limitados en el área de TI, lo que restringe la realización de procesos manuales complejos y refuerza la necesidad de automatización.
- **Entorno operativo en producción:**
  Los servidores soportan servicios críticos municipales, por lo que cualquier cambio debe minimizar el impacto en la disponibilidad y continuidad del servicio.

8.2 Supuestos del escenario

- Se asume que la **Alcaldía Municipal de Santa Ana** proporcionará acceso controlado a los servidores Linux necesarios para el análisis y definición del escenario.
- Se asume la disponibilidad de **entornos de prueba o ventanas de mantenimiento**, que permitan aplicar y validar las configuraciones de hardening sin afectar servicios críticos.
- Se considera que el equipo de TI colaborará en la revisión, validación y adopción de las políticas de hardening definidas en el proyecto.
- Se asume que la entidad está dispuesta a **adoptar buenas prácticas de seguridad** y a mejorar progresivamente sus procesos de gestión tecnológica.

---

9. Validación del Documento

El presente documento ha sido **revisado y validado por los integrantes del grupo de trabajo**, verificando la coherencia entre los objetivos del proyecto, la matriz de gestión de riesgos y los requerimientos definidos.

Asimismo, se confirma que la información presentada refleja de manera adecuada el contexto tecnológico y organizativo de la **Alcaldía Municipal de Santa Ana**, y que los requerimientos propuestos contribuyen a la mitigación de los riesgos identificados, sirviendo como base para futuras implementaciones de automatización y seguridad en la infraestructura de servidores Linux.

A. Sistemas o aplicaciones clave (contexto + puntos de acceso)

Activo A1: Portal web de administración / Back-office (interno)

Qué es y para qué se utiliza: Aplicación interna usada por operaciones/soporte/compliance para gestión de usuarios, revisión de transacciones, resolución de incidencias y tareas administrativas.

Por qué es relevante: Es un destino frecuente del acceso remoto; requiere segmentación y control estricto porque concentra operaciones sensibles.

Activo A2: Consolas de administración de infraestructura en nube (paneles de control)

Qué es y para qué se utiliza: Consolas para administrar recursos en la nube (instancias, redes, firewalls/SG, balanceadores, almacenamiento, etc.).

Por qué es relevante: Un acceso remoto comprometido a estas consolas puede derivar en toma total de la infraestructura (alto impacto).

Activo A3: Servidores de aplicaciones internos (producción y soporte)

Qué es y para qué se utiliza: Conjunto de servidores/servicios que soportan APIs internas, microservicios, colas de procesamiento y componentes de plataforma.

Por qué es relevante: Desde el acceso remoto se administran, parchean o diagnostican; una mala segmentación permitiría ataques laterales.

Activo A4: Herramientas de monitoreo operativo (APM/observabilidad/monitoreo de transacciones)

Qué es y para qué se utiliza: Paneles y sistemas para observar métricas, disponibilidad, alertas y comportamiento transaccional.

Por qué es relevante: Soporte y operaciones los consultan de forma remota; un atacante podría ocultar huellas o interrumpir monitoreo.

B. Infraestructura tecnológica (acceso remoto + red)

Activo B1: Servidor VPN corporativo (OpenVPN o WireGuard) + configuración

Qué es y para qué se utiliza: Servidor que termina túneles VPN y aplica políticas de autenticación, cifrado, rutas y segmentación por perfiles.

Por qué es relevante: Es el núcleo del escenario; si se compromete, se convierte en puerta de entrada a redes internas.

Activo B2: Firewall perimetral / Security Groups / ACLs de red Qué es y para qué se utiliza: Controles que limitan tráfico entrante/saliente y segmentan accesos a redes y servicios internos.

Por qué es relevante: Define el "qué se puede alcanzar" desde la VPN; errores de reglas generan exposición de servicios.

Activo B3: Segmentos de red internos (subredes: producción, soporte, back-office, testing)

Qué es y para qué se utiliza: Subredes separadas para aislar entornos y aplicar mínimo privilegio.

Por qué es relevante: La segmentación es clave para reducir movimiento lateral desde un acceso remoto comprometido.

Activo B4: Bastion host / Jump server (si aplica)

Qué es y para qué se utiliza: Servidor intermedio para administrar recursos internos, evitando acceso directo a servidores críticos.

Por qué es relevante: Reduce superficie de ataque y concentra controles/registro; es un patrón común para administración segura.

Activo B5: Dispositivos remotos autorizados (laptops corporativas o equipos controlados)

Qué es y para qué se utiliza: Equipos desde donde usuarios/soporte/proveedores se conectan a la VPN.

Por qué es relevante: El estado del endpoint (parches, malware) condiciona el riesgo; un equipo comprometido puede “entrar” por la VPN.

Activo B6: Servicio de DNS interno / resolución de nombres interna (si aplica)

Qué es y para qué se utiliza: Permite que usuarios remotos resuelvan servicios internos por nombre durante la conexión.

Por qué es relevante: Afecta operatividad y puede ser vector de abuso (redirigir tráfico, suplantación) si está mal protegido.

C. Datos o información crítica (evidencia, control, auditoría)

Activo C1: Registros (logs) de conexión VPN y autenticación

Qué es y para qué se utiliza: Evidencia de sesiones: usuario, hora, IP origen, duración, fallos de login, eventos de autenticación.

Por qué es relevante: Base para detección de anomalías, investigación de incidentes y auditoría de accesos.

Activo C2: Repositorio de llaves/certificados/credenciales VPN

Qué es y para qué se utiliza: Almacena certificados, llaves privadas, secretos y material criptográfico para acceso VPN.

Por qué es relevante: Compromiso de este repositorio permite suplantación de usuarios o acceso persistente.

Activo C3: Registros de cambios de configuración (bitácora de cambios del servidor VPN y red)

Qué es y para qué se utiliza: Historial de modificaciones (qué cambió, quién lo autorizó, cuándo, por qué).

Por qué es relevante: Permite control, trazabilidad y respuesta ante fallos por cambios no autorizados.

Activo C4: Datos sensibles accesibles desde redes internas (contexto)

Qué es y para qué se utiliza: Bases de datos o reportes internos (clientes, transacciones, KYC/AML, reportes financieros).

Por qué es relevante: Aunque el foco es la VPN, estos datos son el objetivo de alto valor; justifican segmentación estricta y MFA.

D. Herramientas o plataformas de seguridad (control preventivo y detectivo)

Activo D1: Plataforma de gestión de identidades y accesos (IAM) / Directorio de usuarios

Qué es y para qué se utiliza: Gestión de usuarios, roles, políticas de autenticación y (si aplica) MFA.

Por qué es relevante: Integra el control de acceso; errores aquí permiten privilegios excesivos o cuentas huérfanas.

Activo D2: SIEM o repositorio central de logs (si aplica)

Qué es y para qué se utiliza: Centraliza, correlaciona y alerta sobre eventos de seguridad (VPN, firewall, sistemas).

Por qué es relevante: Mejora detección; sin esto, incidentes pasan desapercibidos y se pierde evidencia.

Activo D3: Herramienta EDR/antimalware en endpoints (si existe) / política de endpoint

Qué es y para qué se utiliza: Protege equipos remotos contra malware y comportamientos maliciosos.

Por qué es relevante: Reduce riesgo de “túnel desde equipo comprometido”, una amenaza explícita del escenario.

Activo D4: Sistema de tickets / mesa de ayuda (ITSM) para solicitudes y aprobaciones

Qué es y para qué se utiliza: Canal formal para solicitar accesos, registrar aprobaciones, incidentes y cambios.

Por qué es relevante: Aporta trazabilidad y evidencia; evita accesos informales sin control.

E. Documentación, políticas y procedimientos (gobernanza del escenario)

Activo E1: Política de acceso remoto (VPN) y estándar de segmentación por roles

Qué es y para qué se utiliza: Define quién puede conectarse, bajo qué condiciones, y a qué recursos por perfil.

Por qué es relevante: Sin política, la VPN se vuelve “acceso total”; es la base de mínimo privilegio.

Activo E2: Procedimiento de provisión/revocación de accesos (alta, baja, recertificación)

Qué es y para qué se utiliza: Pasos formales para otorgar, cambiar o revocar accesos; incluye proveedores y vigencias.

Por qué es relevante: Evita cuentas huérfanas y reduce riesgo de accesos indebidos prolongados.

Activo E3: Procedimiento de respuesta a incidentes de acceso remoto (playbook VPN)

Qué es y para qué se utiliza: Guía de contención, investigación y recuperación ante credenciales robadas, fuerza bruta, equipo comprometido.

Por qué es relevante: Reduce tiempo de respuesta y errores en crisis; mejora consistencia y evidencia.

Activo E4: Documentación técnica de la VPN (arquitectura lógica, parámetros de cifrado, rutas, perfiles)

Qué es y para qué se utiliza: Describe diseño, configuración y criterios técnicos (qué está permitido y por qué).

Por qué es relevante: Es el entregable base de requerimientos; apoya auditoría, mantenimiento y continuidad.

4.2. Clasificación de criticidad de activos

A continuación, la clasificación **Crítico / Importante / De apoyo**, con justificación breve (1–2 líneas).

Crítico

- **B1 Servidor VPN + configuración:** Si se compromete o cae, se pierde el control del acceso remoto o se habilita intrusión directa a redes internas.
- **B2 Firewall/SG/ACLs:** Un error o compromiso expone servicios internos o permite movimiento lateral masivo.
- **C2 Repositorio de llaves/certificados/credenciales:** Su pérdida/robo permite suplantación y accesos persistentes difíciles de detectar.
- **D1 IAM/Directorio:** Fallos o abuso generan privilegios indebidos y acceso no autorizado a recursos críticos.
- **C1 Logs de VPN/autenticación:** Si se pierden o alteran, se elimina evidencia y se dificulta detección e investigación de incidentes.
- **A2 Consolas de nube:** Compromiso puede derivar en control total de infraestructura, exfiltración o interrupción del servicio.

Importante

- **B3 Segmentos de red internos:** Si están mal definidos o se mezclan, aumenta la superficie de ataque; afecta mínimo privilegio.
- **B5 Dispositivos remotos autorizados:** Un endpoint comprometido puede introducir amenazas por el túnel; afecta confidencialidad e integridad.
- **A1 Back-office interno:** Exposición permite manipular procesos operativos; impacto alto en fraude o errores, aunque mitigable por segmentación.
- **A3 Servidores de aplicaciones internos:** Riesgo de indisponibilidad y compromiso; su criticidad puede variar según el componente.
- **D2 SIEM/central de logs:** Sin correlación/alertas se reduce capacidad de detección temprana; la operación sigue, pero con mayor riesgo.

- **E1 Política de acceso remoto:** Sin política se degrada el control; el riesgo crece por decisiones ad hoc e inconsistentes.

De apoyo

- **D4 Sistema de tickets/ITSM:** Si falla, se reduce trazabilidad y control administrativo; la operación puede continuar temporalmente, pero con riesgo.
- **E2 Procedimiento de provisión/revocación:** Su ausencia no tumba el servicio, pero genera cuentas huérfanas y accesos excesivos en el tiempo.
- **E3 Playbook de incidentes VPN:** Sin guías, se responde de forma reactiva; aumenta tiempo de contención, pero el servicio puede seguir operando.
- **E4 Documentación técnica de la VPN:** Sin documentación se dificulta mantenimiento/auditoría; no es operativo en tiempo real, pero es clave para continuidad.
- **B6 DNS interno (si aplica):** Fallas afectan usabilidad y acceso por nombre; puede mitigarse temporalmente con IPs/hosts, pero impacta operación.

6. Requerimientos del Escenario

Objetivo de esta sección: Definir qué se espera que el proyecto logre (funcionalmente) y

6.1. Requerimientos funcionales

A continuación, se presenta un conjunto de requerimientos funcionales alineados al escenario **"Acceso remoto seguro mediante VPN (OpenVPN/WireGuard) para una fintech (FinPay)"**. Cada requerimiento incluye **código**, **descripción** y **actores involucrados**.

RF-01 – Autenticación de usuarios remotos en el servicio VPN

Descripción: La solución de acceso remoto debe permitir que los usuarios autorizados se autentiquen para establecer el túnel VPN utilizando credenciales nominales (no compartidas) y un mecanismo de autenticación definido por la organización (usuario/contraseña, certificados/llaves, o combinación).

Actores involucrados: Usuario remoto (interno/proveedor), Administrador IAM, Administrador de Seguridad, Administrador de Infraestructura.

RF-02 – Gestión de perfiles y grupos de acceso por rol

Descripción: La solución debe permitir crear y administrar perfiles/grupos de acceso VPN (por ejemplo: Operaciones, Soporte, DevOps, Cumplimiento, Proveedores) para aplicar el principio de mínimo privilegio.

Actores involucrados: Administrador de Seguridad, Administrador de Infraestructura, Administrador IAM, Jefatura TI.

RF-03 – Segmentación de acceso a recursos internos según perfil

Descripción: La solución debe permitir segmentar el acceso a redes, hosts y puertos internos, de forma que cada perfil VPN solo pueda alcanzar los recursos estrictamente necesarios para su función.

Actores involucrados: Administrador de Infraestructura, Administrador de Seguridad, SOC/Monitoreo (validación), Usuarios remotos (consumidores).

RF-04 – Provisión (alta) de accesos VPN con flujo de aprobación

Descripción: El proceso de acceso remoto debe permitir el alta de usuarios VPN mediante una solicitud formal (ticket o formulario), con aprobación definida por rol/criticidad y asignación de perfil VPN correspondiente.

Actores involucrados: Usuario solicitante, Jefatura TI o dueño de área, Administrador IAM, Administrador de Seguridad.

RF-05 – Modificación de accesos VPN por cambios de rol

Descripción: El proceso debe permitir modificar permisos y perfil VPN cuando un usuario cambie de función, asegurando que se retiren accesos innecesarios y se mantenga trazabilidad del cambio.

Actores involucrados: Administrador IAM, Administrador de Seguridad, Dueño de área, Usuario.

RF-06 – Revocación inmediata de accesos VPN por baja o incidente

Descripción: El proceso debe permitir revocar el acceso VPN de forma inmediata cuando un usuario sea dado de baja, cuando un acceso expire (proveedores) o cuando exista sospecha/confirmación de compromiso.

Actores involucrados: Administrador IAM, Administrador de Seguridad, SOC/Monitoreo, Jefatura TI.

RF-07 – Emisión y administración de material criptográfico (certificados/llaves) cuando aplique

Descripción: La solución debe permitir emitir, rotar, revocar y registrar certificados/llaves asociadas a usuarios y/o dispositivos, asegurando entrega y almacenamiento seguro.

Actores involucrados: Administrador de Infraestructura, Administrador de Seguridad, Administrador IAM.

RF-08 – Registro de eventos de conexión y autenticación (logging VPN)

Descripción: La solución debe registrar eventos mínimos de conexión VPN: inicio/fin de sesión, usuario, IP origen, fallos de autenticación, duración y perfil asignado.

Actores involucrados: Administrador de Infraestructura, SOC/Monitoreo, Seguridad, Cumplimiento/Auditoría.

RF-09 – Consulta y consolidación de logs para auditoría e investigación

Descripción: La solución debe permitir consultar y consolidar logs del servicio VPN y controles asociados (firewall/SG), para soportar auditorías e investigaciones de incidentes.

Actores involucrados: SOC/Monitoreo, Seguridad, Cumplimiento/Auditoría, Infraestructura.

RF-10 – Monitoreo de disponibilidad del servicio VPN

Descripción: La solución debe permitir monitorear el estado del servicio VPN (disponibilidad, sesiones activas, carga, errores) y notificar fallas al equipo responsable.

Actores involucrados: Infraestructura, SOC/Monitoreo, Operaciones/Soporte (escalamiento).

RF-11 – Detección y generación de alertas por eventos anómalos

Descripción: El escenario debe permitir generar alertas ante eventos definidos como sospechosos: múltiples fallos de login, accesos desde ubicaciones/horarios inusuales, intentos repetidos, sesiones excesivas, o conexiones simultáneas del mismo usuario.

Actores involucrados: SOC/Monitoreo, Seguridad, Infraestructura.

RF-12 – Control de acceso para proveedores externos con vigencia y alcance limitado

Descripción: El proceso debe permitir crear accesos temporales para proveedores, con fecha de expiración, alcance mínimo (solo recursos del componente soportado) y registro de actividad.

Actores involucrados: Dueño de servicio, Administrador IAM, Seguridad, Proveedor, Infraestructura.

RF-13 – Procedimiento documentado de gestión de cambios del servidor VPN

Descripción: El escenario debe incluir un proceso documentado para cambios (parches, algoritmos, rutas, perfiles), con validación previa (idealmente en entorno simulado), aprobación y plan de reversa.

Actores involucrados: Infraestructura, Seguridad, DevOps/SRE, Jefatura TI.

RF-14 – Soporte a laboratorio simulado para validación del diseño (opcional pero recomendado)

Descripción: El escenario debe permitir definir (y si el grupo lo decide, implementar) un entorno simulado con una VM como servidor VPN y clientes de prueba, representando segmentos de red (producción/testing/back-office) para validar segmentación y controles.

Actores involucrados: Infraestructura, Seguridad, Estudiantes (equipo del proyecto), Usuarios de prueba.

6.2. Requerimientos no funcionales

A continuación, se proponen requerimientos no funcionales para asegurar calidad, seguridad, operación y cumplimiento del esquema VPN. Cada uno incluye **código**, **descripción** y **justificación**.

RNF-01 – Disponibilidad del servicio VPN

Descripción: El servicio VPN debe estar disponible para soportar operación extendida (incluyendo atención de incidentes fuera de horario), con un nivel de disponibilidad objetivo definido por la entidad (por ejemplo, alta disponibilidad en horarios críticos).

Justificación: La fintech opera servicios financieros digitales; caídas de acceso remoto retrasan respuesta a incidentes y operación.

RNF-02 – Confiabilidad y estabilidad de sesiones

Descripción: El servicio VPN debe mantener sesiones estables, minimizando desconexiones inesperadas y permitiendo reconexión controlada cuando haya fallos de red.

Justificación: Operaciones, soporte y DevOps requieren acceso continuo para tareas críticas y resolución de incidentes.

RNF-03 – Rendimiento (latencia y capacidad de conexión)

Descripción: La VPN debe ofrecer latencia y ancho de banda suficientes para tareas remotas típicas (administración, acceso a paneles, soporte), y soportar la cantidad de usuarios concurrentes esperada para la operación.

Justificación: Rendimiento deficiente provoca uso de canales alternos inseguros y afecta continuidad operativa.

RNF-04 – Escalabilidad

Descripción: La solución debe permitir incorporar nuevos usuarios/perfiles (por crecimiento del negocio o incorporación de proveedores) sin rediseñar completamente la arquitectura.

Justificación: Las fintech suelen crecer rápido; el acceso remoto debe acompañar el crecimiento sin perder control.

RNF-05 – Seguridad criptográfica mínima

Descripción: La solución debe utilizar cifrado robusto y configuraciones seguras (algoritmos recomendados, llaves/certificados protegidos, deshabilitar configuraciones débiles), acorde a políticas internas.

Justificación: El túnel VPN protege datos sensibles y acceso a recursos internos; cifrado débil incrementa riesgo de exposición.

RNF-06 – Autenticación fuerte y control de acceso

Descripción: El acceso remoto debe aplicar autenticación fuerte según criticidad del perfil (idealmente MFA para perfiles privilegiados y para acceso a sistemas sensibles) y prohibir cuentas compartidas.

Justificación: El robo de credenciales es una amenaza probable; MFA y cuentas nominales reducen intrusiones.

RNF-07 – Principio de mínimo privilegio y segregación por roles

Descripción: La segmentación y autorizaciones deben asegurar que cada perfil VPN solo acceda a redes/servicios necesarios; accesos privilegiados deben ser excepcionales y controlados.

Justificación: Limita movimiento lateral y reduce impacto en caso de compromiso de un usuario o dispositivo.

RNF-08 – Trazabilidad y retención de evidencia

Descripción: Los logs de autenticación, conexión, cambios de configuración y eventos relevantes deben conservarse por el período definido por la política de la fintech, con controles que preserven integridad y acceso restringido.

Justificación: Es esencial para auditoría, cumplimiento y reconstrucción de incidentes.

RNF-09 – Monitoreo continuo y alertamiento

Descripción: Debe existir monitoreo del estado del servicio VPN y alertas ante patrones anómalos definidos (fallos repetidos, ubicaciones inusuales, cambios no autorizados, picos de actividad).

Justificación: Sin detección temprana, los incidentes se prolongan y se pierde capacidad de contención rápida.

RNF-10 – Gestión de cambios controlada y documentada

Descripción: Toda modificación del servicio VPN, reglas de segmentación o parámetros criptográficos debe seguir un proceso de control de cambios con aprobación, pruebas (preferiblemente en entorno simulado) y plan de reversa.

Justificación: Cambios mal ejecutados pueden abrir brechas o provocar indisponibilidad del acceso remoto.

RNF-11 – Usabilidad operativa

Descripción: El acceso VPN debe ser suficientemente sencillo para el usuario final (guías claras, configuración replicable, soporte), evitando que se busquen atajos inseguros.

Justificación: La complejidad excesiva incentiva prácticas inseguras (uso de herramientas externas o accesos directos).

RNF-12 – Cumplimiento y alineación con políticas internas

Descripción: El diseño del acceso remoto debe alinearse con políticas internas de seguridad y requisitos de control de acceso lógico propios de organizaciones financieras (aprobaciones, evidencia, revisión periódica de accesos).

Justificación: En fintech, la trazabilidad de accesos y la protección de datos son críticas para auditorías y continuidad del negocio.

8. Restricciones y Supuestos del Escenario

Objetivo de esta sección: Dejar claros los límites y condiciones asumidas para el diseño del escenario.

8.1. Restricciones tecnológicas

RT-01 – Uso de solución VPN open source (OpenVPN o WireGuard)

La solución de acceso remoto del escenario debe basarse en una tecnología **open source** tipo **OpenVPN o WireGuard** (u otra equivalente justificada), evitando soluciones cerradas como dependencia obligatoria.

Implicación: El diseño debe considerar capacidades reales de la herramienta (autenticación, gestión de llaves/certificados, logging, segmentación mediante rutas/reglas).

RT-02 – Infraestructura predominantemente en nube e integración con red interna

El escenario asume que FinPay tiene infraestructura principal en **nube** y posiblemente algunos componentes **on-premise**; el diseño VPN debe contemplar ruteo/segmentación compatible con entornos cloud (subredes, security groups, ACL, firewall perimetral).

Implicación: La segmentación y el control de tráfico dependerán de elementos de red del proveedor de nube y de reglas del sistema operativo del servidor VPN.

RT-03 – Conectividad variable de usuarios remotos

Los usuarios remotos (operaciones, soporte, DevOps, cumplimiento, proveedores) se conectan desde ubicaciones diversas con conectividad variable (ISP doméstico, redes móviles, redes corporativas de terceros).

Implicación: Se debe diseñar tolerancia a latencia, reconexión y mecanismos operativos para evitar “canales alternos” inseguros.

RT-04 – Capacidad limitada de laboratorio / entorno simulado

Si el grupo decide construir un laboratorio, se limita a recursos típicos de práctica: **VM** local o en nube, redes virtuales simuladas, y clientes de prueba. No se asume acceso a infraestructura productiva real.

Implicación: El laboratorio debe usar datos ficticios/no sensibles y configuraciones representativas, no credenciales reales de una fintech.

RT-05 – Restricciones de integración con IAM/MFA (dependencia de madurez tecnológica)

La integración de la VPN con un sistema IAM centralizado o MFA puede estar condicionada por lo que la entidad ya tenga (directorio, proveedor MFA, métodos permitidos).

Implicación: El diseño debe plantear alternativas: MFA obligatorio para perfiles privilegiados “si está disponible”, o controles compensatorios (certificados nominales, endurecimiento, monitoreo y alertas) cuando MFA no sea viable.

RT-06 – Restricciones de visibilidad/registro según componentes disponibles

El nivel de monitoreo y correlación puede depender de si existe SIEM o central de logs.

Implicación: Si no hay SIEM, el diseño debe definir al menos un mecanismo de consolidación y revisión periódica de logs (manual/automatizado), sin perder trazabilidad.

8.2. Restricciones organizativas

RO-01 – Personal limitado y roles compartidos

La fintech puede operar con equipos pequeños donde una persona cubre múltiples funciones (infraestructura + seguridad + soporte).

Implicación: Los procesos deben ser **simples**, claros y sostenibles, evitando sobrecargar operación con controles inviables.

RO-02 – Ventanas de cambio restringidas (operación 24/7)

Por ser un servicio digital financiero, los cambios en producción (VPN, firewall, ruteo, segmentación) podrían requerir ventanas específicas, aprobaciones y plan de reversa.

Implicación: El diseño debe incluir control de cambios y pruebas previas para reducir riesgo de indisponibilidad.

RO-03 – Políticas internas de acceso y segregación por función

Existen políticas internas (aunque dispersas) sobre contraseñas, accesos, proveedores, y manejo de datos. Algunas áreas pueden resistirse a cambios que limiten acceso “por conveniencia”.

Implicación: El documento debe priorizar mínimo privilegio y justificarlo con riesgos del negocio, definiendo excepciones controladas.

RO-04 – Restricciones sobre uso de dispositivos y BYOD

Puede existir mezcla de equipos corporativos y equipos personales (BYOD) para trabajo remoto, o controles inconsistentes de postura de seguridad.

Implicación: El diseño debe proponer políticas mínimas de endpoint y, si no se puede controlar, aplicar controles compensatorios (segmentación estricta, MFA, monitoreo reforzado).

RO-05 – Dependencia de terceros (proveedores y socios tecnológicos)
Proveedores necesitan acceso remoto a componentes específicos y no siempre siguen los mismos estándares internos.

Implicación: Se requiere control estricto de accesos temporales, alcance mínimo, vigencia, recertificación y revocación inmediata.

RO-06 – Exigencias de auditoría interna y cumplimiento

Cumplimiento/Auditoría puede solicitar evidencia de accesos, cambios y revisiones.

Implicación: La trazabilidad no es opcional: debe existir retención de logs, bitácoras y reportes periódicos.

8.3. Supuestos del escenario

S-01 – Colaboración de áreas clave

Se asume que operaciones, soporte, DevOps, seguridad e infraestructura aportarán información mínima para entender necesidades de acceso remoto, perfiles y recursos requeridos.

S-02 – Existencia de un inventario básico de recursos internos

Se asume que FinPay cuenta (o puede construir) un listado mínimo de redes/servicios internos a los que se requiere acceso remoto (aunque no esté formalmente documentado hoy).

S-03 – Disposición para aplicar mínimo privilegio

Se asume que la dirección acepta el principio de mínimo privilegio y permitirá restringir accesos por rol, aun cuando implique cambios en hábitos de trabajo.

S-04 – Posibilidad de usar entorno de prueba o laboratorio simulado

Se asume que el grupo puede diseñar (y opcionalmente implementar) un entorno simulado con VM y redes virtuales para validar segmentación y controles sin tocar producción.

S-05 – Uso exclusivo de información no sensible en el proyecto académico

Se asume que cualquier evidencia, captura o documentación usada por el grupo se basará en datos ficticios, enmascarados o no sensibles, evitando exponer información real de clientes/transacciones.

S-06 – Capacidad de documentar procesos y evidencias

Se asume que el grupo mantendrá bitácoras, control de versiones y evidencias mínimas de decisiones (aprobaciones simuladas, matriz de perfiles, registros de cambios), para respaldar requerimientos y la matriz de riesgo.

S-07 – Escalamiento y respuesta ante incidentes definida al menos a nivel conceptual

Se asume que existe un responsable (real o simulado) para tomar decisiones de contención (revocación, bloqueo, rotación de llaves) cuando se identifique un evento de acceso remoto sospechoso.

9. Validación del Documento de Requerimientos

Objetivo de esta sección: Mostrar que el grupo revisó y acordó la versión final de los requerimientos del escenario.

9.1. Resumen de hallazgos principales

En el escenario **"Acceso remoto seguro mediante VPN (OpenVPN/WireGuard) para una fintech (FinPay)"**, se identificó que la organización opera servicios financieros digitales (billetera, pagos y APIs) con necesidad de acceso remoto para operaciones, soporte, DevOps, cumplimiento y proveedores. La situación actual refleja un acceso remoto potencialmente heterogéneo, con controles dispersos, documentación limitada, y brechas relevantes como ausencia de segmentación estricta por roles, aplicación inconsistente de autenticación fuerte (incluyendo MFA cuando aplique), y registros que no siempre están centralizados o listos para auditoría. Dado que el acceso remoto habilita tareas críticas (atención de incidentes, administración de infraestructura, monitoreo transaccional), el diseño debe equilibrar seguridad y continuidad operativa.

Los activos más importantes para el escenario incluyen el **servidor VPN y su configuración**, los **controles de red** (firewall/SG/ACL), la **gestión de identidades (IAM)**, el **repositorio de llaves/certificados**, y los **logs de conexión/autenticación** como evidencia. Entre los riesgos más relevantes se destacan el **robo de credenciales**

(phishing/fuerza bruta), el acceso desde **equipos remotos comprometidos**, la **mala segmentación** que facilite movimiento lateral, la **exposición innecesaria de servicios internos** y la pérdida o insuficiencia de **trazabilidad** para auditoría e investigación. Para abordar el escenario, se consideran clave los requerimientos relacionados con: autenticación nominal y fuerte, segmentación por perfiles y mínimo privilegio, provisión/revocación controlada de accesos, logging y retención de evidencia, monitoreo y alertamiento de eventos anómalos, y control especial de accesos de proveedores con vigencia y alcance limitado.

9.2. Validación interna del grupo

Se deja constancia de que **todos los integrantes del grupo revisaron el presente documento**, verificaron la coherencia entre contexto, actores, procesos, activos, riesgos y requerimientos, y **acordaron que este corresponde a la "versión validada de requerimientos del escenario"**. Esta versión será utilizada como base para el desarrollo del segundo entregable del proyecto: **la Matriz de Riesgos del Escenario**, incluyendo probabilidad, impacto, nivel de riesgo y controles propuestos.